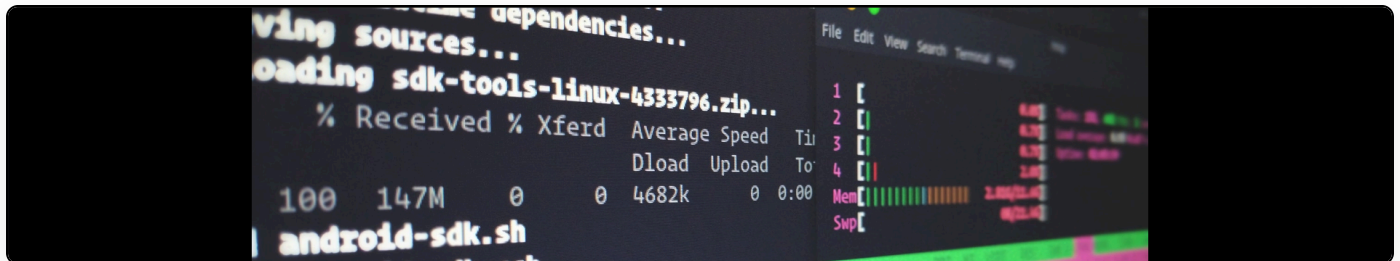


PoC Code for Facebook Friend Profile Gatherer

Cite as: Martin Paul Eve, "PoC Code for Facebook Friend Profile Gatherer", *eve.gd: Martin Paul Eve*, April 26, 2010, <https://doi.org/10.59348/3e1k9-xp590>.



The code on this page iterates over Facebook profile IDs, employing the [CSS History Hack](#) to determine whether each profile has been visited by you. Much of this work is indebted to [Jeremiah Grossman](#) and [Robert Hansen](#). This PoC stores NO information about you, but illustrates how easy it would be for a blackhat to do so.

An explanation of some of the JavaScript herein:

- It uses a `setInterval` call to keep the UI responsive with a callback time of 13ms. This seems to be enough, on my system, to leave the browser functional, while operating at maximum speed. Credits to this method to [James Edwards](#).
- It employs mod 10 loop unrolling to optimize the repeated calls. Furthermore, the loop uses countdown, as opposed to countup as in all JS implementations this is faster. (Don't ask).
- The loop starts at 500800000 in the search for profile URLs. This is because I found that most Facebook profile registrations for my tests were within this numerical ordering.

A server-side lookup of usernames is performed by the following python cgi script:

```
#!/usr/bin/env python
# -*- coding: utf-8 -*-
import cgi
import cgitb; cgitb.enable()

print "Content-type: text/html"
print
form = cgi.FieldStorage()
id = form.getfirst("id", "")

if id != "":
    from urllib import urlopen
    import re
    data = urlopen('http://www.facebook.com/profile.php?id=' + str(int(id))).read()
    p = re.compile('.*?([a-zA-Z\s]+) is on Facebook.*', re.MULTILINE)

    m = p.search(data)

    if m:
        print m.group(1)
    else:
        print id
```

The implications of the disclosure of this data is obvious. With as few as two hits it would be possible to begin intersecting public information to narrow down the likely identity of the visitor. It would also, obviously, be extremely easy for spammers to market their products with what appeared as customized messages: "Your Friend recommended this to you!" etc.

The boring stuff

NAME: Facebook friend list stealing PoC

AUTHOR: Martin Eve

BSD LICENSE:

Copyright (c) 2010, Martin Eve

All rights reserved.

Redistribution and use in source and binary forms, with or without modification, are permitted provided that the following conditions are met:

- * Redistributions of source code must retain the above copyright notice, this list of conditions and the following disclaimer.
- * Redistributions in binary form must reproduce the above copyright notice, this list of conditions and the following disclaimer in the documentation and/or other materials provided with the distribution.
- * Neither the name of the Martin Eve nor the names of its contributors may be used to endorse or promote products derived from this software without specific prior written permission.

THIS SOFTWARE IS PROVIDED BY THE COPYRIGHT HOLDERS AND CONTRIBUTORS "AS IS" AND ANY EXPRESS OR IMPLIED WARRANTIES, INCLUDING, BUT NOT LIMITED TO, THE IMPLIED WARRANTIES OF MERCHANTABILITY AND FITNESS FOR A PARTICULAR PURPOSE ARE DISCLAIMED. IN NO EVENT SHALL THE COPYRIGHT OWNER OR CONTRIBUTORS BE LIABLE FOR ANY DIRECT, INDIRECT, INCIDENTAL, SPECIAL, EXEMPLARY, OR CONSEQUENTIAL DAMAGES (INCLUDING, BUT NOT LIMITED TO, PROCUREMENT OF SUBSTITUTE GOODS OR SERVICES; LOSS OF USE, DATA, OR PROFITS; OR BUSINESS INTERRUPTION) HOWEVER CAUSED AND ON ANY THEORY OF LIABILITY, WHETHER IN CONTRACT, STRICT LIABILITY, OR TORT (INCLUDING NEGLIGENCE OR OTHERWISE) ARISING IN ANY WAY OUT OF THE USE OF THIS SOFTWARE, EVEN IF ADVISED OF THE POSSIBILITY OF SUCH DAMAGE.